UNIVERSITÉ CHEIKH AHMADOUL KHADIM - UCAK

UFR MET - Département IT / Administration et Sécurité Réseaux

MISE EN PLACE D'UNE SOLUTION DE GESTION DES VULNÉRABILITÉS (VMS)

Laboratoire EVE-NG reproduisant l'architecture du Data Center du Rectorat
(double liaison FO, cœur IOSv L3, 2 bâtiments, cloud IaaS — 15 nœuds + 2 clouds)

LIVRABLE 6

Objectif spécifique 7 : « Évaluer l'efficacité de la solution mise en place »

Campagne de non-régression (Atelier C) · continuité de service — bascule double liaison FO (Lab 6) · indicateurs d'efficacité finaux (taux de remédiation, régression, MTTR) · éléments du rapport final

Réalisé par	Makane SECK	Proposition / encadrement	Dr. Abdoul Aziz CISS (EPT)
Date de rendu	23 / 10 / 2026	Référentiel du lab	Documents 06 (Lab 6 + Atelier C) · 04 §11-§12 — livrables 1 à 5

Ce document suit le guide des labs (06 — Lab 6 + Atelier C) et la spécification de l'objectif 7. C'est le livrable de synthèse : il prouve que la solution tient dans le temps (non-régression), que la plateforme tient la panne (continuité), et il mesure l'écart entre les objectifs et le réalisé.

1. Objectif — la preuve par la durée et la panne

L'objectif 7 clôt la démarche : là où les livrables 2 à 5 prouvaient que la chaîne détection → priorisation → remédiation → pilotage fonctionne à l'instant t, celui-ci prouve qu'elle tient dans le temps (campagne de non-régression Atelier C : toutes les remédiations sont rejouées par le scan, les résiduels assumés restent stables, un piège volontaire — telnet replanté sur SW-MET — est détecté puis refermé par la boucle) et que la plateforme elle-même reste en service pendant la panne (Lab 6 : bascule de la double liaison FO, scans continus pendant la coupure). Enfin, les indicateurs d'efficacité font le bilan final et alimentent le rapport de synthèse.

2. Atelier C — la campagne de non-régression

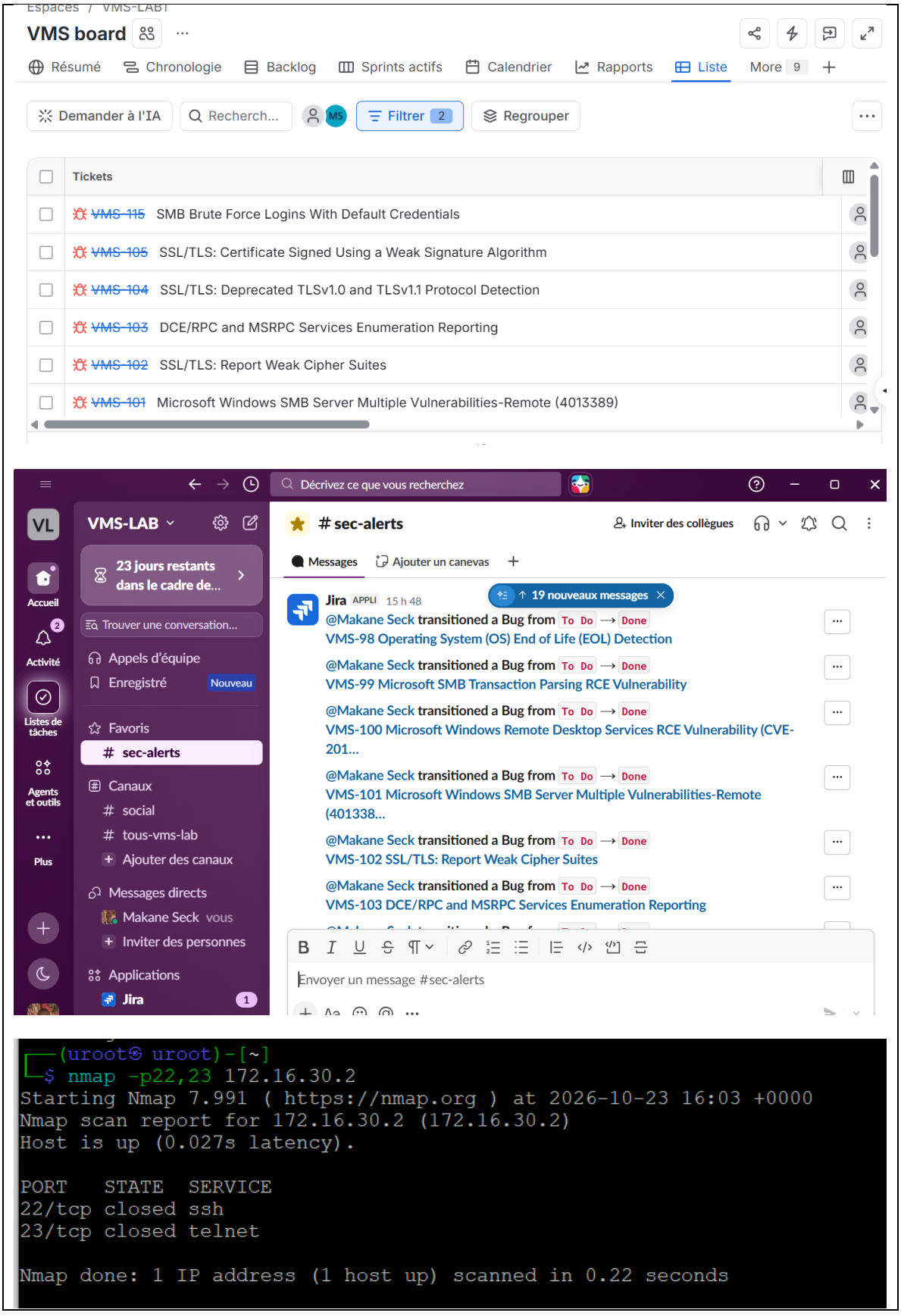
Toutes les remédiations des livrables précédents sont re-scannées dans les mêmes conditions que leur détection (mêmes profils authentifiés, credentials à jour — la règle du mémoire) : ce qui a été corrigé doit rester corrigé, ce qui était assumé doit rester stable, et un piège volontaire (telnet replanté sur SW-MET, comme un firewall mal refermé) doit être détecté, remédié et clôturé par la boucle complète. Attendus par actif :

Actif	Ce qui doit tenir	Relevé (non-régression)
Win-7 ×2 (.30.50 / .31.10)	SMBv1 fermé, MS17-010 absent, mdp fort, RDP fermé (BlueKeep absent)	21/10 : 0/0/1/2 et 0/0/0/2 — conforme
SRV-CLOUD (10.9.1.10)	sudo corrigé tient ; kernel gelé stable (V-04 assumé) ; svc-app + MACs SSH	21/10 : 0/0/8/3 — conforme
Windows-10 (.30.10 / .31.11)	mdp fort tient ; TLS anciens (cosmétique) ; .31.11 : remédiation mdp/updates à consolider	21/10 : 0/0/2/1 chacun — conforme
Camera (.30.11)	page durcie + mdp fort ; sudo High = risk accepted formalisé (IoT, SSH réservé à l'audit)	21/10 : 0/1/8/4 — stable et assumé
Switches / IOS	creds SNMP 06 Lab 1 en place ; pas de retour du telnet fermé en L1 (nmap -p23) ; l'engagement DD (volontairement vide) sert de théâtre au piège (PREUVE 2)	nmap -p22,23 : 23 closed → OK
Clôtures tardives	constats Critical/High Win-7/Win-10 (SLA -9 rouges) clôturés par re-scans « Clôturer les anciennes »	OK

```
# piège volontaire (protocole Atelier C) — replant telnet SW-MET, puis :
conf t
 line vty 0 4
  transport input telnet
 end
→ scan ciblé → constat telnet détecté (alerte Slack + ticket) → remédiation : transport
input ssh
→ re-scan → constat clôturé automatiquement = boucle complète de la figure 1 du mémoire
```

PREUVE 1

Non-régression par actif : DD (réimport « Clôturer les anciennes » dans le même engagement) pour les actifs suivis — Win-7/Win-10 : Criticals barrés, SLA rouges disparus ; SRV-CLOUD : 0/0/8/3 confirmé — et rapports GCE / Nmap pour les actifs sans historique DD : Camera (rapport 21/10) et SW-MET (nmap -p22,23 : telnet fermé).


Espaces / VMS-LAB1
VMS board
Résumé
Chronologie
Backlog
Sprints actifs
Calendrier
Rapports
Liste
More 9
Demander à l'IA
Recherch...
Filtrer 2
Regrouper
Tickets
VMS-115 SMB Brute Force Logins With Default Credentials
VMS-105 SSL/TLS: Certificate Signed Using a Weak Signature Algorithm
VMS-104 SSL/TLS: Deprecated TLSv1.0 and TLSv1.1 Protocol Detection
VMS-103 DCE/RPC and MSRPC Services Enumeration Reporting
VMS-102 SSL/TLS: Report Weak Cipher Suites
VMS-101 Microsoft Windows SMB Server Multiple Vulnerabilities-Remote (4013389)
Décrivez ce que vous recherchez
VMS-LAB
23 jours restants dans le cadre de...
Trouver une conversation...
Appels d'équipe
Enregistré
Nouveau
Favoris
sec-alerts
Canaux
social
tous-vms-lab
Ajouter des canaux
Messages directs
Makane Seck vous
Inviter des personnes
Applications
Jira
sec-alerts
Inviter des collègues
Messages
Ajouter un canevas
19 nouveaux messages
Jira APPLI 15 h 48
@Makane Seck transitioned a Bug from To Do → Done
VMS-98 Operating System (OS) End of Life (EOL) Detection
@Makane Seck transitioned a Bug from To Do → Done
VMS-99 Microsoft SMB Transaction Parsing RCE Vulnerability
@Makane Seck transitioned a Bug from To Do → Done
VMS-100 Microsoft Windows Remote Desktop Services RCE Vulnerability (CVE-201...
@Makane Seck transitioned a Bug from To Do → Done
VMS-101 Microsoft Windows SMB Server Multiple Vulnerabilities-Remote (401338...
@Makane Seck transitioned a Bug from To Do → Done
VMS-102 SSL/TLS: Report Weak Cipher Suites
@Makane Seck transitioned a Bug from To Do → Done
VMS-103 DCE/RPC and MSRPC Services Enumeration Reporting
Envoyer un message #sec-alerts
┌──(uroot㉿uroot)-[~]
└─$ nmap -p22,23 172.16.30.2
Starting Nmap 7.991 (https://nmap.org) at 2026-10-23 16:03 +0000
Nmap scan report for 172.16.30.2 (172.16.30.2)
Host is up (0.027s latency).
PORT STATE SERVICE
22/tcp closed ssh
23/tcp closed telnet
Nmap done: 1 IP address (1 host up) scanned in 0.22 seconds

PREUVE 2

Le piège telnet : détection (constat + ticket/alerte) → remédiation → clôture automatique.

Vulnerability	Severity	QoD	Host IP	Host Name	Location	EPSS Score	EPSS Percentile
Telnet Unencrypted Cleartext Login	4.8 (Medium)	70 %	172.16.30.2	172.16.30.2	23/tcp	N/A	N/A

VMS-95 DCE/RPC and MSRPC S...	À faire	4 janv.	-
VMS-116 DCE/RPC and MSRPC ...	À faire	4 janv.	-
VMS-117 SSL/TLS: Deprecated ...	À faire	4 janv.	-
VMS-118 DCE/RPC and MSRPC ...	À faire	19 janv.	-
VMS-119 SSL/TLS: Deprecated ...	À faire	19 janv.	-
VMS-120 Telnet Unencrypted Cl...	À faire	21 janv.	-

+ Créer

OpenVAS Parser You can find details here: http://172.16.1.20:8080/test/30

Jira APPLI 17 h 25

@Makane Seck transitioned a Bug from To Do → Done

VMS-120 Telnet Unencrypted Cleartext Login

Tickets
~~VMS-120~~ Telnet Unencrypted Cleartext Login
~~VMS-115~~ SMB Brute Force Logins With Default Credentials
~~VMS-105~~ SSL/TLS: Certificate Signed Using a Weak Signature Algorithm
~~VMS-104~~ SSL/TLS: Deprecated TLSv1.0 and TLSv1.1 Protocol Detection
~~VMS-103~~ DCE/RPC and MSRPC Services Enumeration Reporting
~~VMS-102~~ SSL/TLS: Report Weak Cipher Suites

Fri, Oct 23, 2026 4:57 PM Coordinated Universal Time	Done	SW-MET	2.1 (Low)	0	0	0	1

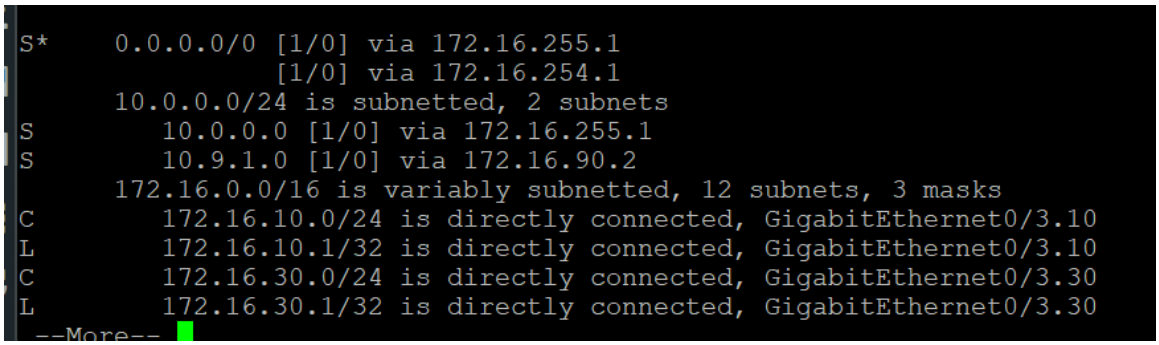
3. Lab 6 — continuité de service : bascule de la double liaison FO

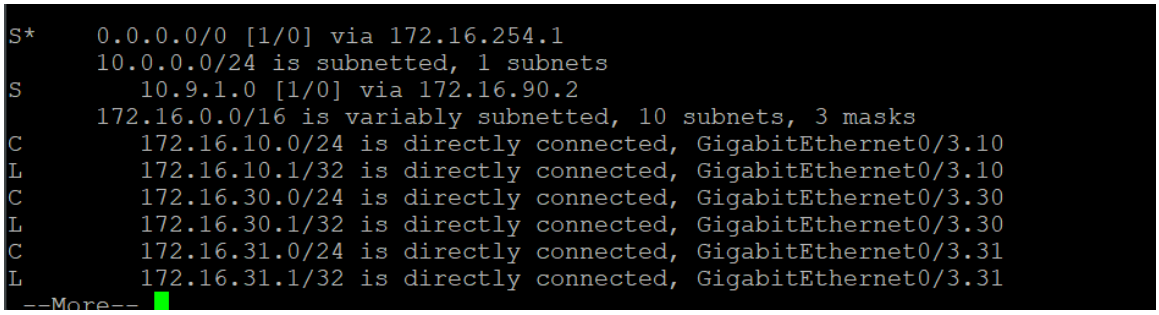
La disponibilité fait partie de l'efficacité : la surveillance ne sert pas si la plateforme meurt avec la panne. Le Lab 6 coupe la FO principale (MADIYANA) au port du cœur (R-CE, G0/0 — un port virtuel ne propage pas la rupture : couper R-CE-1 seul ne déclencherait pas le basculement) et vérifie que la route de secours (CE-2, flottante distance 252) prend le relais sans interrompre ni les scans ni le tunnel :

```
AVANT  (R-CE cœur) : show ip route → défaut via 172.16.255.1 (CE-1) + flottante 172.16.254.1
dist 252
COUPURE : conf t → interface G0/0 → shutdown        (cœur, côté DC)
APRÈS  : show ip route → défaut désormais via 172.16.254.1 (CE-2, flottante montée)
   Windows-10 : ping 10.0.0.254 (internet simulé) → redevient OK (quelques pings perdus au
basculement)
   GCE : ping 10.9.1.10 = OK (le tunnel IPSec est sur 172.16.90.0/30 — il ne bouge pas)
   Fast Scan lancé PENDANT la coupure → se termine normalement (VLAN 10 indépendant des
liaisons opérateur)
RESTITUTION : no shutdown G0/0 → retour à 172.16.255.1
```

PREUVE 3

show ip route avant (172.16.255.1) et pendant/après coupure (172.16.254.1) + ping Windows-10 redevient OK (pings perdus documentés).





```
┌──(uroot㉿uroot)-[~]
└─$ ping 172.16.30.10 -c 3
PING 172.16.30.10 (172.16.30.10) 56(84) bytes of data.
64 bytes from 172.16.30.10: icmp_seq=1 ttl=127 time=136 ms
64 bytes from 172.16.30.10: icmp_seq=2 ttl=127 time=76.6 ms
64 bytes from 172.16.30.10: icmp_seq=3 ttl=127 time=103 ms

--- 172.16.30.10 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2243ms
rtt min/avg/max/mdev = 76.578/105.186/136.065/24.338 ms

┌──(uroot㉿uroot)-[~]
└─$
```

PREUVE 4

Fast Scan lancé et terminé PENDANT la coupure + ping 10.9.1.10 OK (le tunnel ne bascule pas).

Date ↓	Status ↑↓	Task ↑↓	Severity ↑↓	Critical ↑↓	High ↑↓	Medium ↑↓	Low
Fri, Oct 23, 2026 4:43 PM Coordinated Universal Time	98 %	SRV-CLOUD-Remédié	6.5 (Medium)	0	0	8	3

```
┌──(uroot㉿uroot)-[~]
└─$ ping 10.9.1.10 -c 3
PING 10.9.1.10 (10.9.1.10) 56(84) bytes of data.
64 bytes from 10.9.1.10: icmp_seq=1 ttl=63 time=158 ms
64 bytes from 10.9.1.10: icmp_seq=2 ttl=63 time=30.1 ms
64 bytes from 10.9.1.10: icmp_seq=3 ttl=63 time=25.6 ms

--- 10.9.1.10 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2007ms
rtt min/avg/max/mdev = 25.556/71.181/157.846/61.309 ms
```

4. L'évaluation de l'efficacité — le bilan par les indicateurs

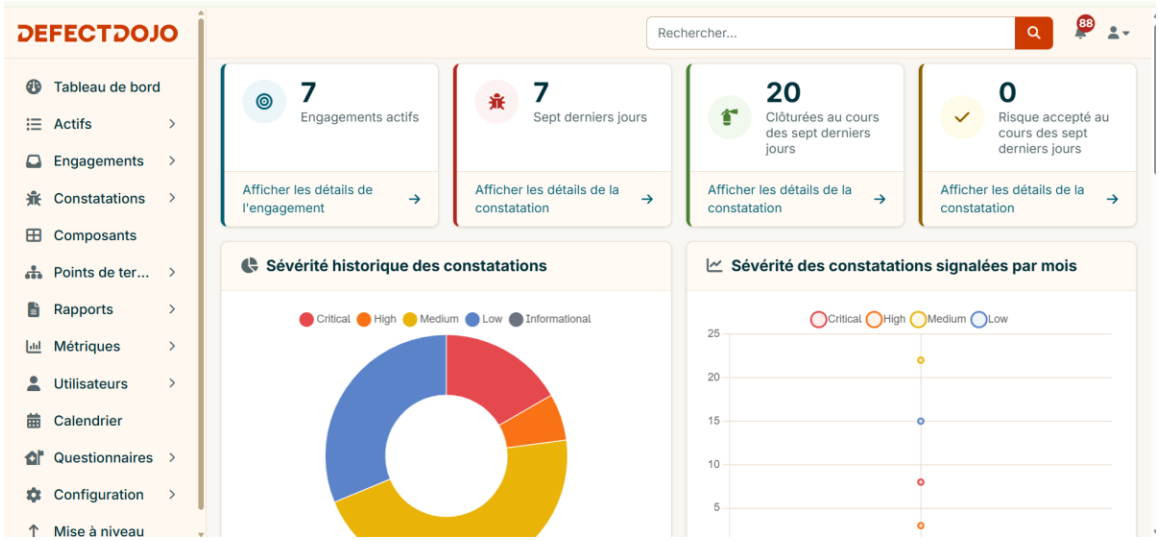
Indicateur d'efficacité	Formule	Valeur finale	Cible
Taux de remédiation	constats fermés / ouverts	≈ 1,05 — 20 fermés / ≈ 19 actifs (vague de clôture du 22/10)	> 1, croissant
Taux de régression	constats « Re-opened » / fermés	0 % — aucun Re-opened : la non-régression est prouvée	≈ 0 %
MTTR constaté	clôture − 1re détection (DD)	sudo : 14 j (référence)	Critique ≤ 30 j
Couverture	actifs surveillés / P0	6 / 6 — 100 %	100 %
Remédiation automatisée	playbooks / correctifs	Camera 100 % Ansible	≥ 50 % à terme

PREUVE 5

Tableur KPI final mis à jour (10_preuve3_tableau_kpi.xlsx complété) + dashboard DefectDojo (métriques finales).

VMS — TABLEAU DE BORD KPI (Livrable 5, Obj. 6) — relevé du 21/10/2026

Indicateur	Formule / source	Valeur relevée	Cible / seuil
1. Couverture	actifs scannés / inventaire P0	6 / 6 — 100 %	100 % des actifs vitaux
2. Critiques VLAN 30 (campus)	rapports GCE + matrice RBVM (L3)	MS17-010, SMB RCE, BlueKeep : corrigés ET clôturés le 22/10 (re-scans « Clôturer les anciennes » — Criticals barrés, SLA rouges disparus)	0
3. Critiques cloud (10.9.1.10)	rapport Full authentifié	0 — confirmé par le Full du 21/10 (0/0/8/3)	0
4. MTTR / MTTM	(date de clôture − 1re détection) — DefectDojo	14 j (sudo : détecté 02/10, fermé 16/10)	Critique ≤ 30 j · High ≤ 60 j
5. Tendance critiques/scan	cycles L1 → L2 → APRÈS → suivi	3C/1H → 9C/3H → 0C/0H → 0C/1H → 0C/0H (clôtures du 22/10)	décroissante
6. Âge moyen des constats ouverts	DefectDojo (1re détection − aujourd'hui)	15-16 j (moyenne ≈ 15) — dédup conserve la 1re détection	critique > 30 j = alerte
7. Taux de remédiation automatisée	correctifs par playbook / total	Camera : 100 % Ansible · sudo : manuel	≥ 50 % à terme
8. Taux de remédiation (bilan L6)	constats fermés / ouverts actifs	≈ 1,05 — 20 fermés / ≈19 actifs (vague de clôture 22/10)	> 1, croissant
9. Taux de régression	constats « Re-opened » / fermés	0 % — aucun Re-opened (non-régression prouvée)	≈ 0 %



5. Limites assumées et perspectives

Limite constatée	Statut	Perspective de production
8 Medium « kernel » sur SRV-CLOUD (Ubuntu 20.04 gelé)	risk accepted formalisé — scénario V-04	mise à niveau de l'OS / LTS intermédiaire
sudo High sur la Camera (Baron Samedit)	risk accepted — IoT, exposé VLAN 30 seul, SSH réservé à l'audit	mise à jour firmware / 2e playbook Ansible
TLS 1.0/1.1 sur les Windows (cosmétique, non authentifié critique)	constaté, priorisé bas	GPO crypto durcie
correctif sudo appliqué manuellement (hors chaîne Ansible)	documenté au L4	AWX : webhook CVE → playbook ciblé
Fast quotidien = authentification partielle	choix de coût (RAM)	agents locaux + fenêtres ouvrées (postes éteints)

6. Ce que ce livrable apporte au rapport final

Le rapport de synthèse réutilisera : l'architecture reproduite au lab (15 nœuds + 2 clouds EVE-NG, double FO) ; la méthodologie (baseline → authentifié → priorisation RBVM → workflow → pilotage → non-régression) ; les résultats mesurés (tendance 3C/1H → 9C/3H → 0C/0H, MTTR 14 j, couverture 100 %, boucle de clôture automatique prouvée, bascule FO sans interruption des scans) ; les limites assumées ci-dessus et les perspectives. C'est la démonstration complète que la GdV est un processus, pas un projet : détecter, prioriser, corriger, prouver, recommencer.